OSINT Cyber Risk Assessment Report

Broadridge Financial Solutions, Inc. (NYSE: BR)

Prem Kumar Santhanam

Vellanki Himaja Chowdary

Jyothi P

Mayank Desai

Pace University

Course Number: CYB 651 – Cyber Intelligence Analysis & Modeling

Prof. Nathifa Lewis

May 12,2026

Table of Contents

Executive Summary 3
Company Overview 4
Network Hardware and Infrastructure 5
2.1 Cloud Infrastructure — Amazon Web Services (AWS) 5
2.2 Legacy Infrastructure — Kyndryl Managed Services 6
2.3 DNS Infrastructure — UltraDNS 6
2.4 F5 BIG-IP Load Balancing / Access Policy Infrastructure 6
Software and Technology Stack 7
3.1 Security Operations & Monitoring 7
3.2 Identity & Access Management 8
3.3 Privileged Access Management — BeyondTrust 8
3.4 IT Service Management — ServiceNow 8
3.5 Email Security — Proofpoint 8
3.6 Third-Party Vendor Software (SPF Record Analysis) 9
Key Personal 10
DNS and Email Infrastructure Analysis 11
5.1 DNS Record Summary 11
5.2 DNSSEC Gap 11
5.3 SPF SoftFail Configuration 11
Vulnerability and CVE Analysis 12
6.1 CVE-2024-12356 — BeyondTrust Privileged Remote Access (Critical) 12
6.2 CVE-2025-53521 — F5 BIG-IP Access Policy Manager (Critical RCE) 13
6.3 Additional CVE Risk Surface 13
Social Engineering and Attack Surface 14
7.1 Executive Targeting — Business Email Compromise 14
7.2 Vendor Impersonation 14
7.3 New Employee / Helpdesk Pretexting 15
Risk Assessment Matrix 15
Recommended Mitigations 16
9.1 **Fix 1 — Patch or Upgrade BeyondTrust (CVE-2024-12356)** 16
9.2 **Fix 2 — Enable DNSSEC for broadridge.com** 16
9.3 **Fix 3 — Third-Party Risk Management (TPRM) Program** 17
Conclusion 17
Reference 19

Executive Summary

This research paper presents a comprehensive, passive open-source intelligence (OSINT) assessment of Broadridge Financial Solutions, Inc. (NYSE: BR), It is a Fortune 500 financial technology firm processing approximately $10 trillion in daily securities transactions globally. The research was completed as part of CYB 651: Cyber Intelligence Analysis & Modeling, using publicly available tools including MXToolbox, Robtex, the CISA Known Exploited Vulnerabilities (KEV) catalog, LinkedIn, and Broadridge's own Trust Center publications. No active scanning, penetration testing, or employee contact was conducted at any point during this study.

Our analysis has uncovered a layered technology environment built on Amazon Web Services (AWS) cloud infrastructure, enterprise DNS via UltraDNS, email filtering through Proofpoint, and a mix of on-premises and managed services supported by Kyndryl (formerly IBM Infrastructure Services). We have identified and confirmed Two high-priority vulnerabilities : CVE-2024-12356, a critical command injection flaw in BeyondTrust Privileged Remote Access, and CVE-2025-53521, a critical unauthenticated remote code execution vulnerability in F5 BIG-IP Access Policy Manager, for which Broadridge publicly confirmed exposure on 15 internet-facing devices. Additionally, two DNS configuration gaps were observed, one is an unsigned DNSSEC and the other one is SoftFail SPF policy. We felt these were meaningful weaknesses in Broadridge's email and DNS security posture.

The social engineering attack surface is sizable, with confirmed executive names, a high-confidence email format, and active social media presence creating fertile ground for business email compromise (BEC) and spear-phishing. Overall, Broadridge demonstrates mature security investment, but specific, verifiable weaknesses in third-party vendor exposure and email security configuration needs immediate attention.

Company Overview

Broadridge Financial Solutions, Inc. was spun off from Automatic Data Processing (ADP) in 2007 and has since grown into one of the most critical pieces of financial market infrastructure in the world. Headquartered at 5 Dakota Drive, Suite 300, Lake Success, New York 11042, the company employs more than 15,000 people across 21 countries and maintains a market capitalization in the tens of billions of dollars.

Broadridge's core business spans across three segments: Investor Communication Solutions (proxy voting and shareholder communications), Global Technology and Operations (trade processing, clearing, and settlement services), and last one is Wealth and Capital Markets. The company processes approximately $10 trillion in daily fixed income, equity, and fund transactions on behalf of institutional clients that include the world's largest banks, broker-dealers, asset managers, and wealth management firms.

The company's scale and systemic importance to financial markets make it an attractive target for nation-state cyber actors and financially motivated ransomware groups alike. A successful attack on Broadridge's core trade processing infrastructure could have cascading effects across global securities markets and it is a fact reflected in the company's own disclosure that cybersecurity and operational resilience are now "strategic imperatives."

Attribute	Detail
Legal Name	Broadridge Financial Solutions, Inc.
Stock Ticker	NYSE: BR
Founded	2007 (ADP spin-off)
Headquarters	5 Dakota Drive, Lake Success, NY 11042
Employees	~15,000+ across 21 countries
Daily Trade Volume	~$10 trillion (securities)
Revenue (FY2025 Est.)	> $6 billion
Clients	Banks, broker-dealers, asset managers, wealth firms
LinkedIn Followers	268,000+ (verified company page)
Primary Services	Trade processing, proxy voting, shareholder comms

Table 1: Broadridge Financial Solutions – Company Profile Summary

Broadridge's acknowledged role in processing securities for virtually every major financial institution in the United States places it under intense regulatory scrutiny from the SEC, FINRA, and increasingly the Digital Operational Resilience Act (DORA) in the European Union. The company has publicly noted that it processes more than $6 trillion in fixed income transactions daily through its Distributed Trade Management (DTM) platform alone, and it acts as the Super Validator on the Canton Network blockchain, further extending its technology footprint into emerging digital asset infrastructure.

Network Hardware and Infrastructure

Understanding the physical and logical network infrastructure of a target organization is a foundational step in any OSINT-based risk assessment. For Broadridge, passive DNS queries, WHOIS lookups, and public SEC filings revealed a multi-layered hybrid infrastructure combining public cloud, managed services, and on-premises mainframe systems.

2.1 Cloud Infrastructure — Amazon Web Services (AWS)

Broadridge's primary internet-facing web presence is hosted on Amazon EC2 instances. Using MXToolbox's DNS lookup tool and Robtex's IP trace functionality, the domain broadridge.com was found to resolve to three IP addresses: 3.219.78.25, 3.220.212.11, and 3.220.214.71. All three fall within the Amazon EC2 IAD prefix block (3.208.0.0/12), confirming AWS us-east-1 (Northern Virginia) as the primary cloud hosting region.

This is further corroborated by Broadridge's publicly disclosed AWS Cloud Agreement with Presidio Networked Solutions LLC, a reseller of Amazon Web Services. Per their SEC 10-Q filing for Q3 FY2025, this agreement runs through December 31, 2026, and covers "public cloud infrastructure and related services for the operation, management and support of the Company's cloud global distributed platforms and products." The company has committed $83.9 million through March 31, 2030 to a separate Private Cloud Agreement, suggesting a multi-cloud or hybrid model beyond the public AWS footprint.

IP Address	ASN / Provider	Region	Purpose
3.219.78.25	AS14618 — Amazon EC2	us-east-1 (IAD)	Primary web (broadridge.com)
3.220.212.11	AS14618 — Amazon EC2	us-east-1 (IAD)	Primary web (broadridge.com)
3.220.214.71	AS14618 — Amazon EC2	us-east-1 (IAD)	Primary web (broadridge.com)
205.220.164.217	AS26211 — Proofpoint	US (Proofpoint PoP)	Email gateway (MX)

2.2 Legacy Infrastructure — Kyndryl Managed Services

In addition to its cloud presence, Broadridge operates a substantial managed infrastructure environment through Kyndryl, Inc. — the managed infrastructure services entity spun off from IBM. Per SEC filings, Kyndryl provides "certain aspects of the Company's information technology infrastructure, including supporting its mainframe, midrange, network and data center operations, as well as providing disaster recovery services." The Amended and Restated IT Services Agreement with Kyndryl runs through June 30, 2027, with committed payments of $75 million through that date.

The presence of mainframe infrastructure is operationally significant. Broadridge processes high-volume securities transactions through industry convention, often rely on IBM mainframe systems for core clearing and settlement functions. These systems introduce a separate vulnerability surface — IBM z/OS mainframe environments have their own CVE ecosystem, and their integration with modern cloud infrastructure creates potential bridging risks if network segmentation is insufficient.

Additionally, a legacy IP block (167.212.0.0/16) identified through ARIN WHOIS records suggests Broadridge may retain some on-premises infrastructure. ARIN registration places this block with Broadridge, though its current operational status and these are actively used for internal systems or merely retained for historical reasons. These are further require investigation beyond passive means.

2.3 DNS Infrastructure — UltraDNS

Broadridge's authoritative DNS is managed by UltraDNS, a Neustar (now TransUnion) product marketed as enterprise-grade, DDoS-resilient DNS infrastructure. The four nameservers identified via Robtex are: edns1.ultradns.com, edns1.ultradns.net, edns1.ultradns.org, and edns1.ultradns.biz. UltraDNS is commonly used by large financial institutions due to its SLA guarantees for uptime and its built-in anycast routing, which distributes DNS queries across multiple global points of presence to mitigate distributed denial-of-service attacks targeting DNS infrastructure.

2.4 F5 BIG-IP Load Balancing / Access Policy Infrastructure

Broadridge's own public Trust Center confirmed the presence of F5 BIG-IP devices in its environment. Specifically, the October 2025 threat response statement acknowledged 15 internet-facing F5 BIG-IP devices that were identified and scheduled for remediation following the nation-state breach of F5's internal systems. F5 BIG-IP devices are enterprise-grade

application delivery controllers (ADCs) commonly deployed as load balancers, web application firewalls (WAFs), SSL offloaders, and secure access proxies (Access Policy Manager / APM function). The fact that these are described as "internet-facing" suggests they sit in the DMZ or edge of Broadridge's network, handling traffic for client-facing applications.

Hardware/Platform	Role	Confirmed Source
Amazon EC2 (AWS us-east-1)	Cloud web hosting, application delivery	Robtex DNS, MXToolbox, SEC filing
F5 BIG-IP APM (15 devices)	Load balancing, SSL offload, VPN access	Broadridge Trust Center (Oct 2025)
IBM Mainframe (via Kyndryl)	Core transaction processing, legacy compute	SEC 10-Q FY2025
UltraDNS Nameservers	Authoritative DNS with DDoS protection	Robtex DNS trace
Proofpoint Email Gateway	Inbound/outbound email filtering (MX)	MXToolbox MX Lookup
On-Premises / Legacy (167.212.0.0/16)	Potential on-premises datacenter range	ARIN WHOIS (passive)

Table 3: Broadridge Network Hardware & Infrastructure Summary

Software and Technology Stack

The technology platforms operating within Broadridge's environment were profiled through three primary passive OSINT channels: analysis of LinkedIn job postings and employee skill endorsements, DNS TXT record analysis (particularly Microsoft 365 verification tokens), and cross-referencing the vendor names appearing in Broadridge's published SPF record. Each platform identified below represents both an operational asset and a potential vulnerability surface that maps to existing CVE findings.

3.1 Security Operations & Monitoring

Broadridge's security engineering job postings on LinkedIn repeatedly reference Splunk as the primary Security Information and Event Management (SIEM) platform. Splunk is used for log aggregation, correlation, alerting, and security analytics. The presence of a Splunk deployment indicates that Broadridge has a security operations center (SOC) function capable of real-time detection — a positive indicator. However, Splunk has its own CVE history (notably CVE-2023-46214, a critical RCE in Splunk Enterprise) and represents a high-value target if an attacker seeks to blind the SOC before launching a subsequent attack.

3.2 Identity & Access Management

Microsoft Azure Active Directory (Azure AD / Entra ID) is confirmed as Broadridge's identity platform, evidenced by Microsoft 365 verification tokens in the domain's DNS TXT records. Azure AD serves as the central identity provider for Single Sign-On (SSO), multi-factor authentication (MFA), and conditional access policies. In financial services environments, misconfigurations in Azure AD — such as overly permissive Conditional Access policies or improper Privileged Identity Management (PIM) configuration — represent a critical attack vector, as they can grant attackers lateral movement capability across cloud-hosted applications.

3.3 Privileged Access Management — BeyondTrust

LinkedIn job postings for security engineering roles at Broadridge explicitly reference BeyondTrust as the Privileged Access Management (PAM) platform. BeyondTrust products — specifically Privileged Remote Access (PRA) and Remote Support — are used to control and audit privileged user sessions and administrative access to critical systems. This is directly relevant because CVE-2024-12356, a CVSS 9.8 Critical command injection vulnerability in BeyondTrust PRA/RS, was added to the CISA KEV catalog in December 2024 and was actively exploited by the Silk Typhoon nation-state group in the 2024 breach of the U.S. Treasury Department.

3.4 IT Service Management — ServiceNow

ServiceNow is referenced across Broadridge's IT operations and helpdesk job postings. ServiceNow functions as the platform for IT service requests, incident management, change management, and asset tracking. From a social engineering perspective, ServiceNow's presence is noteworthy because it is the system through which employees would process IT-related requests — making it a target for pretexting attacks in which an adversary impersonates a helpdesk agent to reset credentials or escalate access.

3.5 Email Security — Proofpoint

Broadridge's email is routed through Proofpoint's global email security load balancer (GSLB) infrastructure, confirmed via MXToolbox MX lookup. Proofpoint provides advanced threat protection, email filtering, sandboxing of attachments, and URL rewriting for phishing protection. Employee skill endorsements on LinkedIn corroborate Proofpoint usage within Broadridge's email security team. Proofpoint's presence indicates investment in enterprise

email security, but the SoftFail SPF configuration (discussed in Section 6) partially undermines the efficacy of these controls.

3.6 Third-Party Vendor Software (SPF Record Analysis)

The SPF TXT record published at broadridge.com authorizes mail to be sent on Broadridge's behalf from several external vendor systems. This list effectively constitutes a partial inventory of Broadridge's SaaS vendor ecosystem:

- Oracle Eloqua — Marketing automation and email campaign management
- Zixworks — Secure email encryption for compliance-sensitive communications
- Adobe Workfront — Project and work management platform
- Symantec MessageLabs — Legacy email security and archiving
- Proofpoint (pphosted.com) — Outbound email filtering

Each of these vendor relationships represents a potential supply chain attack vector. An attacker who compromises the email infrastructure of any SPF-authorized vendor could send email that appears to originate from Broadridge's domain, bypassing some recipient-side spam and phishing filters.

Technology Platform	Category	Evidence Source	CVE Risk
Splunk Enterprise/Cloud	SIEM / Log Management	LinkedIn job postings	CVE-2023-46214 (Critical RCE)
Microsoft Azure AD / Entra ID	Identity & Access Mgmt	DNS TXT (MS365 token)	Misconfiguration risk
BeyondTrust PRA/RS	Privileged Access Mgmt	LinkedIn security job posts	CVE-2024-12356 (CVSS 9.8)
ServiceNow	IT Service Management	LinkedIn IT operations posts	Social engineering surface
Proofpoint	Email Security Gateway	MX DNS records	SPF SoftFail gap
IBM MQ	Messaging Middleware	LinkedIn capital markets posts	CVE history (IBM MQ)
Oracle Eloqua	Marketing / Email SaaS	SPF record	Third-party supply chain
Adobe Workfront	Work Management SaaS	SPF record	Third-party supply chain
Zixworks	Secure Email Encryption	SPF record	Third-party supply chain
Java / Python / SQL	Development Stack	LinkedIn engineer posts	Dependency/library CVEs

Table 4: Broadridge Software & Technology Stack — Confirmed via Passive OSINT

Key Personal

Identifying an organization's key personnel is a standard component of OSINT-based risk assessment. Executive identities establish the social engineering attack surface — specifically the pretexting and business email compromise (BEC) risk — and can reveal organizational priorities and potential insider access risks. The following individuals were confirmed through Broadridge's official leadership page (broadridge.com/about/leadership), the SEC DEF 14A proxy statement for fiscal year 2025, and LinkedIn.

Name	Title	Relevance to Security Posture
Timothy C. Gokey	Chief Executive Officer (CEO)	Active on LinkedIn; posts public org updates — rich pretexting material
Christopher J. Perry	President	Public profile; accessible via LinkedIn
Ashima Ghei	Chief Financial Officer (CFO)	High-value BEC target; wire transfer authority
Tyler Derr	Chief Technology Officer (CTO)	Owns technology roadmap; cloud & infra decisions
Thomas P. Carey	EVP & Chief Operating Officer (COO)	Operational continuity decisions
Hope M. Jarkowski	Chief Legal Officer (CLO)	Regulatory disclosures; M&A legal actions

Table 5: Broadridge Key Executives Confirmed via SEC DEF 14A FY2025 & broadridge.com/about/leadership

CEO Timothy Gokey is particularly visible in the public domain. He regularly posts on LinkedIn about Broadridge's business strategy, industry conferences (including SIFMA Ops 2025, where he was a featured speaker), and organizational milestones. This level of public visibility, while appropriate for a CEO with investor relations responsibilities, creates a detailed, current, and authentic-sounding profile that threat actors can exploit to craft highly convincing spear-phishing lures impersonating the CEO, or to build pretexts around his known activities and relationships.

The confirmed email format — ***firstname.lastname@broadridge.com*** — means that high-confidence email addresses for all six named executives can be constructed without any internal access. ZoomInfo data corroborates this format as being used by 48.5% of Broadridge accounts. Combined with the publicly known organizational hierarchy from SEC proxy statements, a threat actor could craft a CEO-to-CFO wire transfer fraud email (a classic BEC scenario) with a high degree of authenticity.

DNS and Email Infrastructure Analysis

Passive DNS and email infrastructure analysis was performed using MXToolbox SuperTool (mx lookup and spf lookup functions) and Robtex's DNS trace tool. All lookups were conducted live against broadridge.com's authoritative nameservers on April 13, 2026. Screenshots of each tool output were captured as evidence figures (Figures 1–3 in the original field notes).

5.1 DNS Record Summary

Record Type	Value	Security Implication
A Records	3.219.78.25, 3.220.212.11, 3.220.214.71	All AWS EC2 IPs — cloud-hosted attack surface
NS Records	edns1.ultradns.{com|net|org|biz}	Enterprise DDoS-resilient DNS — positive control
MX Records	mxa/mxb-001b6a02.gslb.pphosted.com	Proofpoint GSLB — enterprise email security in place
TXT (SPF)	v=spf1 include:spf1/2.broadridge.com ~all	SoftFail (~all) — does NOT hard-reject unauthorized senders
TXT (DMARC)	p=quarantine/reject (published)	DMARC policy active — email impersonation mitigation
DNSSEC	Not signed	DNS responses unverified — spoofing/poisoning risk

Table 6: DNS Record Analysis for broadridge.com

5.2 DNSSEC Gap

Robtex's DNS analysis confirmed that broadridge.com is NOT protected by DNS Security Extensions (DNSSEC). DNSSEC adds cryptographic signatures to DNS records, allowing resolvers to verify that responses have not been tampered with in transit. Without DNSSEC, broadridge.com is theoretically vulnerable to DNS cache poisoning attacks, in which an adversary injects false DNS records into a recursive resolver's cache, redirecting users or systems attempting to reach Broadridge's servers to attacker-controlled infrastructure. For a financial services firm of Broadridge's scale, where clients and counterparties regularly access portals for trade confirmations, account statements, and proxy voting, DNS spoofing attacks could have significant operational and reputational consequences.

5.3 SPF SoftFail Configuration

The SPF record for broadridge.com terminates with ~all (tilde-all), which is a "SoftFail" qualifier. Under RFC 7208 (the SPF specification), a SoftFail instructs receiving mail servers to accept the message but mark it as suspicious — it does not hard-reject messages from

unauthorized senders the way a -all (hard fail) record would. This means that an adversary who sends an email spoofing a @broadridge.com sender address will not be automatically rejected by SPF alone. While DMARC provides an additional layer that can enforce rejection based on DKIM and SPF alignment, the SoftFail SPF configuration represents an incomplete implementation of email authentication best practices. Upgrading to -all would close this gap.

The inclusion of multiple third-party senders in the SPF record — spf1.broadridge.com, spf2.broadridge.com, and pphosted.com (Proofpoint) — indicates the use of split SPF records, which is an appropriate management practice but also means the authorized sender list is not directly visible in a single DNS query, potentially obscuring the full scope of email system integrations.

Vulnerability and CVE Analysis

Vulnerability research was conducted exclusively through the CISA Known Exploited Vulnerabilities (KEV) catalog, the National Vulnerability Database (NVD), and Broadridge's own public Trust Center at trust.broadridge.com. No tools capable of active scanning were used. The following vulnerabilities were identified as directly applicable to Broadridge's confirmed technology stack.

6.1 CVE-2024-12356 — BeyondTrust Privileged Remote Access (Critical)

CVE-2024-12356 allows an unauthenticated remote attacker to inject OS-level commands through BeyondTrust's web interface, effectively gaining command execution on the underlying host as the web application service user. No credentials are required, and no user interaction is needed on the victim's side. The exploit is network-accessible, meaning any instance of BeyondTrust PRA or RS exposed to the internet or accessible from a compromised network segment is at risk.

The threat actor relevance is particularly alarming. The same BeyondTrust vulnerability family was leveraged by Silk Typhoon (tracked by Microsoft as a China-nexus APT group) during the 2024 compromise of U.S. Treasury Department systems — a breach that the U.S. government described as a "major cybersecurity incident." Broadridge's confirmed use of BeyondTrust for PAM, evidenced through LinkedIn job postings explicitly calling out BeyondTrust skills as requirements for security engineering roles, means this CVE is directly applicable to Broadridge's risk surface.

6.2 CVE-2025-53521 — F5 BIG-IP Access Policy Manager (Critical RCE)

CVE-2025-53521 is among the most significant vulnerabilities in this assessment because Broadridge's own public Trust Center provides explicit confirmation of F5 BIG-IP device usage and the scope of exposure. In a rare instance of an OSINT target directly documenting its own vulnerability surface, Broadridge's October 17, 2025 Trust Center statement confirmed that 15 internet-facing F5 BIG-IP devices were identified in its environment following F5's disclosure of the nation-state breach, and that all 15 were scheduled for remediation by October 19, 2025.

The subsequent reclassification of CVE-2025-53521 from DoS to Critical RCE in March 2026 changes the calculus significantly. Organizations that applied patches in October 2025 upon F5's original DoS disclosure are protected. However, organizations that deprioritized patching — as many security teams reasonably might for what appeared to be a relatively lower-severity DoS vulnerability — now face a Critical pre-auth RCE flaw that is actively being weaponized. As of March 31, 2026, the Shadowserver Foundation identified over 17,100 BIG-IP APM instances exposed on the public internet. Threat actors are deploying web shells on unpatched devices to establish persistent access.

For Broadridge, the key question that cannot be answered through passive research alone is whether the October 2025 patching effort was fully completed before the March 2026 reclassification elevated the threat level, and whether any web shells or persistence mechanisms were established on the 15 devices during the period between F5's internal breach (estimated at 12+ months before October 2025 disclosure) and the remediation window.

6.3 Additional CVE Risk Surface

Beyond the two primary vulnerabilities confirmed above, the technology stack identified in Section 4 presents additional CVE exposure worth noting:

- IBM MQ (Message Queuing): IBM MQ has a documented CVE history, including vulnerabilities related to denial-of-service, privilege escalation, and information disclosure in various versions. Broadridge's use of IBM MQ for capital markets messaging middleware creates a non-trivial patching obligation.
- Splunk Enterprise: CVE-2023-46214 (CVSS 8.8) allowed authenticated remote code execution via file upload in Splunk Enterprise versions below 9.0.7 and 9.1.2. While patched in late 2023, organizations with slow patch cycles or extended enterprise agreements sometimes remain on vulnerable versions.

- Microsoft Azure AD / Entra ID: Misconfigurations rather than software CVEs are the primary risk vector here. Specifically, overly broad guest user permissions, inadequate Conditional Access policy coverage, and improper Privileged Identity Management (PIM) configuration are consistently cited in CISA advisories as leading causes of cloud environment compromise.

Social Engineering and Attack Surface

Social engineering remains the most consistently successful initial access technique in corporate cybersecurity incidents, accounting for a significant portion of data breaches according to Verizon's annual Data Breach Investigations Report. The passive OSINT research conducted on Broadridge reveals a meaningful social engineering attack surface that a sophisticated threat actor could exploit without ever interacting with a Broadridge employee or system.

7.1 Executive Targeting — Business Email Compromise

- The combination of confirmed executive names (Section 5), predictable email format, and publicly visible LinkedIn activity creates the ingredients for a high-confidence BEC attack. The CEO-to-CFO wire transfer fraud scenario is the most straightforward: an attacker could spoof or compromise a sender appearing to be Timothy Gokey (CEO) and request an urgent wire transfer from Ashima Ghei (CFO), leveraging knowledge of Broadridge's organizational structure from SEC filings to make the request appear legitimate.
- CEO Gokey's public LinkedIn activity also creates a "calendar intelligence" opportunity: by tracking his posted conference appearances (e.g., SIFMA Ops 2025 in May 2025), an attacker could time spear-phishing campaigns to coincide with periods when the CEO is known to be traveling, away from the office, or engaged in external-facing activities — reducing the likelihood of the CEO noticing or being consulted about suspicious requests made in his name.

7.2 Vendor Impersonation

- The SPF record and DNS analysis revealed Broadridge's relationships with Oracle (Eloqua), IBM, Adobe (Workfront), Proofpoint, and Zixworks. A threat actor could impersonate a technical representative from any of these known vendors in a spear-phishing campaign targeting Broadridge employees. For example, a phishing email

appearing to come from "Oracle Eloqua Support" requesting login credentials for an "account migration" would be far more convincing to a Broadridge marketing or IT employee than a generic phishing attempt, because Oracle is a confirmed vendor relationship.

7.3 New Employee / Helpdesk Pretexting

With more than 15,000 employees globally, Broadridge experiences continuous employee onboarding. LinkedIn's job posting data shows active recruitment. ServiceNow's confirmed presence as Broadridge's IT service management platform means that new hire onboarding — including account provisioning, VPN access setup, and password initialization — flows through a ServiceNow portal. A threat actor could pretext as a new employee experiencing onboarding issues to pressure IT helpdesk staff into resetting credentials or granting temporary elevated access.

Risk Assessment Matrix

The following risk matrix applies a standard Likelihood x Impact assessment to the vulnerabilities and weaknesses identified through passive OSINT research. Risk ratings are assigned on a qualitative scale: Critical, High, Medium, or Low. All findings are based solely on publicly available information consistent with the Hayes and Cappa (2018) OSINT risk assessment framework.

Vulnerability	Likelihood	Impact	Risk Level	Recommended Action
DNSSEC Not Signed	Medium	High	HIGH	Implement DNSSEC signing immediately
SPF SoftFail (~all)	Medium	Medium	MEDIUM	Upgrade to hard-fail (-all) policy
CVE-2024-12356 (BeyondTrust)	High	Critical	CRITICAL	Patch/upgrade BeyondTrust; audit PAM
CVE-2025-53521 (F5 BIG-IP)	High	Critical	CRITICAL	Apply F5 patches; validate all 15 devices
Spear-Phishing / BEC Risk	High	High	HIGH	MFA everywhere; user awareness training
Third-Party Supply Chain	Medium	High	HIGH	Vendor risk reviews; TPRM program
IBM MQ Message Broker CVEs	Medium	High	HIGH	Apply IBM security patches; network segment
Azure AD Misconfiguration	Medium	High	HIGH	Conditional Access; privileged identity mgmt

Table 10: Risk Assessment Matrix — Broadridge Financial Solutions

The two Critical-rated risks — CVE-2024-12356 (BeyondTrust) and CVE-2025-53521 (F5 BIG-IP) — both involve actively exploited vulnerabilities confirmed by CISA's KEV catalog. The DNSSEC gap and SPF SoftFail, while rated High, represent configuration-level fixes that are relatively low-cost to implement compared to the exposure they mitigate.

Recommended Mitigations

The following recommendations are derived from the identified vulnerabilities and are grounded in CISA guidance, NIST SP 800-53 controls, and industry best practices for financial services firms. All recommendations are intended for informational and academic purposes only, reflecting the passive research methodology applied throughout this study.

9.1 Immediate Actions (0–30 Days)

Fix 1 — Patch or Upgrade BeyondTrust (CVE-2024-12356)

Broadridge should immediately verify that all instances of BeyondTrust Privileged Remote Access and Remote Support are running versions that include patches for CVE-2024-12356. Given that this vulnerability requires no authentication and allows OS command execution, any unpatched BeyondTrust instance reachable from the internet or an internal attacker-controlled host represents an immediate critical risk. CISA's remediation due date was December 27, 2024 — any delay beyond this point is unacceptable given active exploitation.

- Enumerate all BeyondTrust PRA and RS instances in the environment.
- Apply vendor patches per BeyondTrust's advisory.
- If patching cannot be completed immediately, restrict access to BeyondTrust admin interfaces to IP allowlists (internal management networks only).
- Review BeyondTrust session logs for any evidence of exploitation activity consistent with the known Silk Typhoon TTPs.

9.2 Short-Term Actions (30–90 Days)

Fix 2 — Enable DNSSEC for broadridge.com

Implementing DNSSEC for broadridge.com would close the DNS cache poisoning and spoofing risk identified in Section 6. The process involves generating DNSSEC key pairs, signing the zone's DNS records, and publishing the public keys (DS records) to the parent zone (.com). Since Broadridge uses UltraDNS for authoritative DNS, UltraDNS supports DNSSEC management through its portal, making implementation operationally straightforward.

- Work with UltraDNS to enable DNSSEC signing for broadridge.com.
- Publish DS records to the .com TLD registry.
- Validate DNSSEC deployment using tools like DNSViz or MXToolbox's DNSSEC lookup.
- Extend DNSSEC signing to all subdomains used for client-facing applications.

9.3 Long-Term Strategic Actions (90+ Days)

Fix 3 — Third-Party Risk Management (TPRM) Program

The SPF record analysis revealed at least five third-party SaaS vendors authorized to send email on Broadridge's behalf: Oracle Eloqua, Zixworks, Adobe Workfront, Symantec MessageLabs, and Proofpoint. Each of these relationships represents a supply chain attack vector. The F5 BIG-IP incident itself is an example of a sophisticated supply chain attack — the nation-state actor compromised F5's internal systems to gain access to BIG-IP source code and undisclosed vulnerability data, which was then used against F5's customers.

- Implement or strengthen a formal Third-Party Risk Management (TPRM) program that requires SOC 2 Type II reports and penetration test results from all critical technology vendors.
- Conduct quarterly reviews of SPF-authorized vendors to identify and remove outdated or unnecessary send-on-behalf relationships.
- Require vendors to notify Broadridge immediately of any security incidents affecting systems that interact with Broadridge's environment.
- Evaluate whether Symantec MessageLabs (legacy platform) is still actively used; if not, remove it from the SPF record to reduce the authorized sender surface.

Conclusion

This OSINT-based cybersecurity risk assessment of Broadridge Financial Solutions, Inc. demonstrates both the maturity of Broadridge's security investments and the very real, concrete vulnerabilities that remain in its environment vulnerabilities that can be identified, contextualized, and risk-rated without ever touching the organization's systems or speaking to its employees.

Broadridge operates at the intersection of financial market infrastructure and advanced technology, processing trillions of dollars in daily transactions for the world's most

systemically important financial institutions. This scale makes it both an incredibly well-funded defender and an extraordinarily attractive target. The nation-state actors that breached the U.S. Treasury via BeyondTrust and F5's internal systems have demonstrated a clear pattern of targeting the "plumbing" of financial services — the vendors, platforms, and infrastructure that banks and broker-dealers rely on.

The two Critical-rated vulnerabilities identified in this study — CVE-2024-12356 in BeyondTrust and CVE-2025-53521 in F5 BIG-IP — are not hypothetical risks. They are actively exploited CVEs added to the CISA KEV catalog, linked to confirmed nation-state activity, and directly applicable to Broadridge's confirmed technology stack. The DNSSEC gap and SPF SoftFail represent configuration-level weaknesses that, while less dramatic, provide unnecessary attack surface in an organization's email and DNS infrastructure.

The social engineering attack surface is extensive and largely unavoidable given the public profile requirements of a NYSE-listed company with a CEO who engages actively on LinkedIn. The recommended mitigations are MFA, helpdesk verification procedures, executive awareness training are practical, proven controls that materially reduce the risk without constraining legitimate business communication.

Ultimately, this study illustrates the power of passive OSINT for risk assessment and the critical importance of configuration hygiene, proactive patch management, and vendor risk management in defending financial market infrastructure. As the Hayes and Cappa (2018) framework articulates, open-source intelligence is no longer a technique exclusive to attackers, it is an essential tool for defenders who seek to understand their own external exposure before adversaries do.

Reference

1. Hayes, D. R., & Cappa, F. (2018). Open-source intelligence for risk assessment. Business Horizons, 61(5), 689–697. https://doi.org/10.1016/j.bushor.2018.02.001
2. Broadridge Financial Solutions. (2025, October 17). Threat actors targeting vulnerable F5 devices [Threat response statement]. Broadridge Trust Center. https://trust.broadridge.com
3. Cybersecurity and Infrastructure Security Agency. (2024, December 19). CISA adds one known exploited vulnerability to catalog: CVE-2024-12356 BeyondTrust privileged remote access command injection vulnerability. U.S. Department of Homeland Security. https://www.cisa.gov/news-events/alerts/2024/12/19/cisa-adds-one-known-exploited-vulnerability-catalog
4. Cybersecurity and Infrastructure Security Agency. (2025, October 15). Emergency directive ED 26-01: Mitigate vulnerabilities in F5 devices. U.S. Department of Homeland Security. https://www.cisa.gov/news-events/directives/ed-26-01-mitigate-vulnerabilities-f5-devices
5. Cybersecurity and Infrastructure Security Agency. (2026, March 27). CVE-2025-53521 added to KEV catalog. CISA Known Exploited Vulnerabilities. https://www.cisa.gov/known-exploited-vulnerabilities-catalog
6. F5, Inc. (2025, October 15). Form 8-K: Security incident disclosure [SEC filing]. U.S. Securities and Exchange Commission. https://www.sec.gov/Archives/edgar/data/0001048695/000104869525000149/ex99110152025.htm
7. F5, Inc. (2026, March 28). Security advisory K000156741: BIG-IP APM vulnerability CVE-2025-53521 [Updated]. https://my.f5.com/manage/s/article/K000156741
8. MXToolbox. (2026, April 13). MX lookup results for broadridge.com [OSINT tool output]. https://mxtoolbox.com
9. MXToolbox. (2026, April 13). SPF lookup results for broadridge.com [OSINT tool output]. https://mxtoolbox.com
10. Robtex. (2026, April 13). DNS lookup for broadridge.com [OSINT tool output]. https://robtex.com
11. National Institute of Standards and Technology. (2024, December 17). CVE-2024-12356 detail. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2024-12356

12. National Institute of Standards and Technology. (2025). CVE-2025-53521 detail. National Vulnerability Database. https://nvd.nist.gov/vuln/detail/CVE-2025-53521
13. Broadridge Financial Solutions. (2026, April 13). About Broadridge [LinkedIn company page]. LinkedIn. https://www.linkedin.com/company/broadridge-financial-solutions
14. Broadridge Financial Solutions. (2025). Our leadership team. https://www.broadridge.com/about/leadership
15. Broadridge Financial Solutions. (2025). Proxy statement: Definitive proxy statement (DEF 14A), fiscal year 2025 [SEC filing]. U.S. Securities and Exchange Commission. https://www.sec.gov
16. Broadridge Financial Solutions. (2025). Form 10-Q, fiscal year 2025 [SEC filing]. U.S. Securities and Exchange Commission. https://www.sec.gov
17. Help Net Security. (2026, March 30). Attackers are exploiting RCE vulnerability in BIG-IP APM systems (CVE-2025-53521). https://www.helpnetsecurity.com/2026/03/28/big-ip-apm-vulnerability-cve-2025-53521-exploited/
18. The Hacker News. (2026, March 28). CISA adds CVE-2025-53521 to KEV after active F5 BIG-IP APM exploitation. https://thehackernews.com/2026/03/cisa-adds-cve-2025-53521-to-kev-after.html
19. Broadridge Financial Solutions. (2025, May 7). Growing need for operational and cyber resilience [Press release]. https://www.broadridge.com/press-release/2025/growing-need-for-operational-and-cyber-resilience-dominates-concerns
20. National Institute of Standards and Technology. (2020). Security and privacy controls for information systems and organizations (NIST Special Publication 800-53, Rev. 5). U.S. Department of Commerce. https://doi.org/10.6028/NIST.SP.800-53r5